

Audit methodology and typology

This morning, the Group CISO answered a client who wanted a certificate and a senior management that wanted to move fast, and both answers ran into the same wall: nobody in the MERIDIAN group knows how to measure the gap between what the group claims and what it does. The framework PSSI from session 1 requires MFA on every administration access; the Santé subsidiary lives with local passwords and no MFA. The framework chosen in session 3 expects an inventory kept up to date; who has checked it since session 2? This lecture teaches the trade that answers these questions: the audit, its exact definition, its types, its method, and the discipline of vocabulary without which an audit report becomes a battlefield.

✓ From claim to evidence: why auditing is a trade



Session objectives

By the end of this lecture:



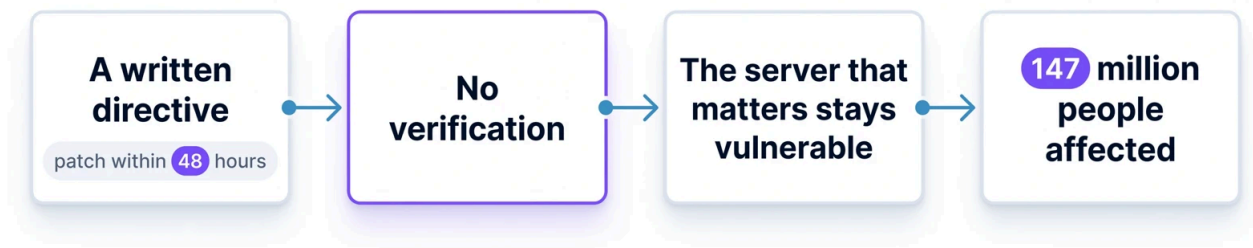
- **Define** what an audit is in the normative sense, and what distinguishes it from a self-assessment or from continuous monitoring
- **Distinguish** finding, deviation, nonconformity and observation, and use each word advisedly
- **Classify** an audit along its two axes: who commissions it (internal, second-party or third-party external) and what it examines (compliance, organizational, configuration, architecture, technical)
- **Describe** the methodical course of an audit, from framing to follow-up, and the conditions that make it trustworthy
- **Position** the standards of the audit family (ISO 19011, ISO/IEC 27007, ISO/IEC 27006) and the French actors (qualified providers, regulators)

Prerequisites

- The group's framework, chosen and imported in session 3: ISO/IEC 27001:2022, with its compliance assessment created in the GRC tool, still blank. It is what the day will begin to fill.
- The session 2 mapping: business assets, supporting assets, DICT needs. An audit is framed on a scope, and the group's is already drawn.
- The framework PSSI directives established in session 1: they will serve as internal audit criteria.
- This morning's "CISO's briefing": the value of a certification, and the state of play set as a precondition to any promise.

The gap nobody measures always ends up measuring itself

First, the story that justifies this entire lecture. In 2017, the US credit agency Equifax suffered a data breach affecting 147 million people, caused, according to the FTC, by a failure to patch a known vulnerability. The detail that matters today: according to the US regulator, Equifax's security team had indeed ordered in 2017, after the alert, that every vulnerable system be patched within 48 hours; the order existed, the directive was written, and nobody checked that it had been applied on the server that mattered. Born of the 2017 breach, the case concluded in 2019 with a settlement of at least 575 million dollars with the US authorities. The exact moral, to remember: Equifax did not lack rules, it lacked verification. An organization that writes requirements without ever measuring their application does not own rules, it owns wishes. Auditing is the trade of that measurement, and everything that follows flows from it.



What auditing means: evidence against criteria

The normative definition fits in one sentence, and every word in it earns its keep. ISO/IEC 27000:2018, the vocabulary of the ISMS family, defines the audit thus: "systematic, independent and documented process for obtaining audit evidence and evaluating it objectively to determine the extent to which the audit criteria are fulfilled". Unpacked: a process that is systematic, independent and documented, which gathers evidence and evaluates it objectively to determine to what extent criteria are satisfied.

The three adjectives deserve to be unfolded, because they are the difference between an audit and a visit.

Systematic means the audit follows a plan and covers what it announced, it does not flit about according to impressions; a tour of the offices looking at whatever catches the eye is not an audit. **Independent** means the auditor does not judge their own work and has nothing to gain from the verdict; the ANSSI and DINUM (the French interministerial digital directorate) guide on security authorization (« homologation ») says it plainly: « L'audit doit être effectué par des auditeurs indépendants et de confiance. » (the audit must be carried out by independent and trusted auditors.) **Documented** means every conclusion is tied to a piece of evidence that is traced, dated, replayable; an audit whose path cannot be walked again is worth no more than an opinion.

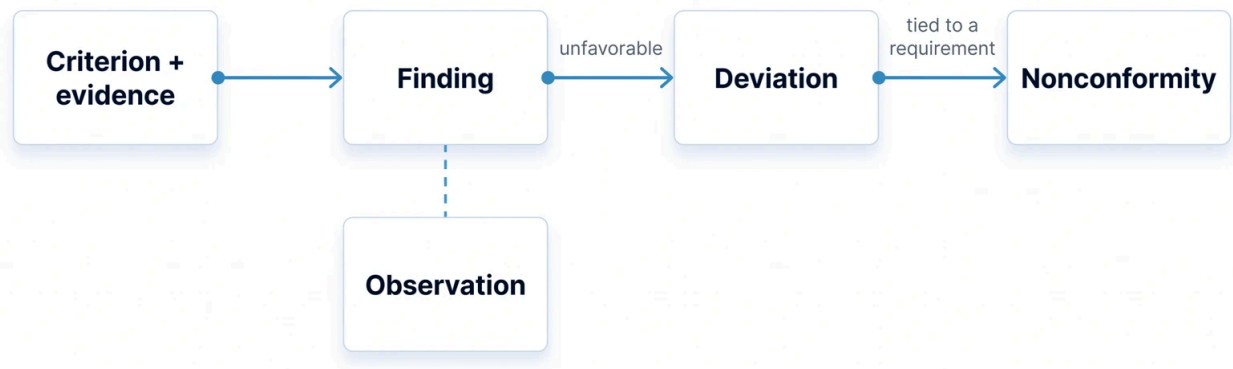
And above all, the two raw materials. The **audit criterion** is the yardstick against which the comparison is made: a framework, an internal policy, a regulation, a contract clause. This is where session 3 pays off: the **audit framework** of the MERIDIAN group is chosen, it is ISO/IEC 27001:2022, joined by the internal criteria, the framework

PSSI directives, and the regulatory criteria of each subsidiary. An audit without an explicit criterion does not exist: whoever says "this is insufficient" without being able to say "against what" is expressing a taste. The **audit evidence**, for its part, is any verifiable element the auditor gathers: a document, an exported configuration, a log, a recorded interview, an on-screen demonstration. The golden rule of the trade: no evidence, no finding.

From the meeting of a criterion and a piece of evidence is born the **audit finding**, and this is where this session's discipline of vocabulary begins. A finding is the result of the evaluation: the evidence, set against the criterion, shows either conformity or something else. These words are not interchangeable, and a CISO who mixes them up manufactures conflicts:

Term	What it designates	What it is not
Finding	The factual result of the evidence/criterion comparison, favourable or not	A value judgement: a finding can be "compliant"
Deviation	An unfavourable finding: the observed situation does not satisfy the criterion	A sanction: the deviation describes, it does not punish
Nonconformity	A deviation formally graded against a precise requirement of the criterion: in the sense of ISO/IEC 27000:2018, "non-fulfilment of a requirement"	A vague synonym for "problem": without a cited requirement, no nonconformity
Observation	What the auditor reports without being able to hook it to a requirement: a risk, a fragility, a practice that could be improved	A deviation: an observation is not "corrected" under threat of sanction, it is looked into

This chain is to be engraved: criterion plus evidence yields a finding; an unfavourable finding yields a deviation; a deviation attached to a requirement yields a nonconformity, which this afternoon's tutorial will teach how to grade as major or minor; a signal without a requirement yields an observation. The idea was already met in outline in the session 3 quiz: assessing compliance means returning a verdict per requirement, never a global verdict decreed in one go.



One last word in this section, because the afternoon depends on it: "**self-assessment** is not an audit". When the subsidiary assesses its own compliance by itself, the middle adjective, independence, is missing; the look remains precious, it prepares the audit, it roughs it out, but it does not replace it. This afternoon's lab will bring it to life: self-assessing with an auditor's rigour, and discovering how hard it is to be severe with one's own work.

✓ The typology: who commissions the audit, and what it examines

The word "audit" covers exercises so different that no serious conversation can rest on the word alone. Two axes are enough to classify everything.

First axis: **who commissions, and for whom**. The note to the ISO/IEC 27000:2018 definition says it in one line: "An audit can be an internal audit (first party) or an external audit (second party or third party)". The **internal audit**, called first-party, is commissioned by the organization on itself, for its own steering; and, a clarification from the same note that always surprises, it can be conducted by an external provider on the organization's behalf: internal does not mean "done by our employees", but "commissioned by us, for us". The **external audit** of second party is commissioned by an interested party, typically a client auditing its supplier: this morning's contracting client questionnaire is its light form, and its possible audit visit would be its complete form. The third-party external audit is conducted by a body independent of both, and it is the world of certification: the certification body audits against ISO/IEC 27001, and it is itself accredited under ISO/IEC 27006, which supplements ISO/IEC 17021 to govern

the bodies that audit and certify ISMSs. The qualification of providers by ANSSI, met in session 3, lives in the same spirit: trust in the auditor is proven, too.

Type	Who commissions	Who audits	Purpose	MERIDIAN example
Internal (first party)	The organization itself	Its teams, or a mandated provider	Steer, prepare, improve	The group's internal audit programme, launched this week
External, second party	An interested party	The client or its representative	Decide on the business relationship	The Logistique contracting client and its panel questionnaire
External, third party	The organization, towards an independent body	An accredited certification body	Attest publicly	The future ISO/IEC 27001 certification audit of Logistique

Second axis: **what the audit examines**. The ANSSI and DINUM security authorization guide, which will return in the tutorial, draws up the list of audit types that French regulations make mandatory depending on the system, and it makes an excellent general typology: the **compliance** audit (« le système d'information est-il conforme aux réglementations applicables ? », i.e. is the information system compliant with the applicable regulations?), the **organizational** audit (the human structure, its resources, its documentation), the **configuration** audit (the settings of the system's components), the **architecture** audit (the coherence of the technical and organizational construction with regard to the security objectives), and the **technical audit**, which brings together the exercises on technical components, intrusion included. The same guide adds that other types adapt to the nature of the system: code reviews, penetration tests, bug bounty programmes. And it states the most useful programme advice on this list: « Lorsque cela est possible, il est préférable d'alterner le type d'audit afin de couvrir le maximum de vulnérabilités pouvant être exploitées par une menace. » (whenever possible, it is preferable to alternate the type of audit so as to cover the maximum of vulnerabilities that a threat could exploit.) A group that redoes the same penetration test on the same scope every year learns the same thing every year.

Two French actors complete this landscape. First, the qualified providers: for information systems of vital importance, the guide specifies that audits must be carried out by a Prestataire d'Audit de Sécurité des Systèmes d'Information, PASSI (information systems security audit provider), qualified through ANSSI's visa programme; one recognizes qualification in the reserved sense seen in session 3, applied this time to auditors. Then the regulators, because there is one last category that no organization commissions: the inspection one undergoes. The CNIL is the most concrete example for MERIDIAN: its report published in 2025 records 321 inspections conducted in 2024, and in its figures published in 2026, nearly 30 % of the sanctions issued concern cybersecurity failings. The fine of 5 million euros issued in 2026 against France Travail, following the 2024 breach that had potentially exposed the data of 43 million people, shows what an inspection finds when the organization has not measured its own deviations: the same deviations, at the worst moment, before the worst audience. To audit is to choose to discover one's weaknesses before someone else discovers them in one's place.

321

INSPECTIONS CONDUCTED BY
THE CNIL IN 2024,
ACCORDING TO ITS REPORT
PUBLISHED IN 2025

CNIL

30%

NEARLY 30 % OF CNIL
SANCTIONS CONCERN
CYBERSECURITY FAILINGS,
FIGURES PUBLISHED IN 2026

CNIL

**5 million
euros**

FINE ISSUED IN 2026
AGAINST FRANCE TRAVAIL
AFTER THE 2024 BREACH

CNIL

Methodology: an audit unfolds, it is not improvised

The guidelines for auditing management systems live in ISO 19011, which the security family specializes: ISO/IEC 27007 provides, in the words of ISO/IEC 27000:2018, guidelines for conducting ISMS audits "in addition to the guidance contained in ISO 19011, which is applicable to management systems in general". That is the complete normative stack of auditing, and it can be remembered in three lines:

Standard	Role	Who uses it
ISO 19011	Guidelines for auditing any management system: principles, programme, conduct	Any auditor, any organization building an audit programme
ISO/IEC 27007	The same guidelines, specialized for auditing an ISMS and for the competence of its auditors	Internal and external ISMS auditors
ISO/IEC 27006, with ISO/IEC 17021	Requirements applicable to bodies that audit and certify ISMSs; the basis of their accreditation	Certification bodies, and those who watch them

These texts are paid-for and will not be quoted line by line; the method that follows is the module's, and each of its guardrails leans on a public requirement of the security authorization guide. It unfolds in five stages.



Framing. Everything starts with three written decisions: the scope, the criteria, the mandate. The scope delimits what the audit covers; ISO/IEC 27000:2018 defines it in one stroke, "extent and boundaries of an audit", and the security authorization guide requires that it match the scope defined for the study of the system. The criteria are set before setting off: audit against which framework, which policies, which texts. The mandate, finally, protects everyone: « L'audit doit être cadré et autorisé par le responsable du système d'information et par sa hiérarchie » (the audit must be framed and authorized by the owner of the information system and by their management), says the guide, and that sentence is not an administrative nicety; a penetration test without a written mandate is a computer attack, whatever the goodwill of its author.

Preparation. The auditor builds the plan: which requirements of the criterion will be covered, which evidence will be requested, who will be met, in what order. Two requirements of the guide frame this stage: « Le temps consacré à un audit doit être suffisant » (the time devoted to an audit must be sufficient), as a rushed audit manufactures false assurance; and « L'auditeur doit être libre de proposer ses propres scénarios » (the auditor must be free to propose their own scenarios), because an auditee who chooses what the auditor will look at has already written the conclusion.

Evidence gathering. The heart of the trade, in four gestures: read, the policies, the procedures, the registers; interview, in recorded interviews, those who do, not only those who describe; observe, on site or on screen, what actually happens; test, when the audit type lends itself to it, from configuration review to penetration test. The hierarchy of evidence is mental hygiene: a demonstration is worth more than a screenshot, a screenshot is worth more than a statement, and a statement alone never closes an important requirement.

Findings and their grading. Each piece of evidence meets its criterion and produces a finding, in the exact vocabulary of the first section. The discipline of writing findings will be half of the tutorial: a good finding cites the criterion, describes the observed situation, references the evidence, and contains neither a mood adjective nor a

culprit. "The domain administration account is shared between the maintenance provider and the internal administrator, in deviation from the PSSI requirement of individual accounts, established in interview and on the directory on the day of the audit": everything is there, and nobody is insulted.

Reporting and follow-up. An audit ends twice. A first time with the report and its presentation, where the findings are set out and discussed, and where the auditee may contest a piece of evidence, never a mood; that is the subject of the day's second lab. A second time, later, with the follow-up: the security authorization guide explicitly ties the frequency of audits « à l'avancement des actions identifiées et corrigées lors des derniers audits » (to the progress of the actions identified and corrected during the latest audits). An audit whose findings produce neither action nor subsequent verification was only a rite. It is through this thread, findings, actions, verification, that the audit feeds the continuous improvement of the system, which session 9 will take as its subject.

✓ MERIDIAN's audit programme: what the week will find

Back to the group: all this vocabulary has ground waiting for it. This week the Group CISO launches the group's first internal audit cycle: scope per subsidiary, three criteria, namely the ISO/IEC 27001:2022 framework chosen in session 3, the framework PSSI directives from session 1, and each subsidiary's regulatory foundation mapped in session 3. This morning sets its method; the afternoon produces the tooled self-assessment of the most exposed subsidiary, then the group's initial audit report.

And the ground is already better known than it seems, because the previous sessions let situations show through that the audit programme will now formally establish. At Santé: local passwords without MFA, when the framework PSSI requires MFA for any remote access or administration privilege; analysis machines and imaging consoles on the same IP range as office IT, with an identical local administration account across the fleet. At Logistique: IT and OT networks interconnected despite the strict segmentation directive, and a domain administration account shared between the third-party maintenance provider and the system administrator. At Éducation: shared administration accounts. At Territoires: logs kept locally, when the group directive requires their collection to the centralized SOC. Each of these situations awaits its transformation into a finding worthy of the name: criterion cited, evidence referenced, neutral wording; then its grading, major, minor or observation, which is exactly the work of the coming tutorial.

One last thing before diving in. The temptation, faced with this list, is to jump straight to solutions: "just deploy MFA". Resist it, for one more day. The professional order is: establish findings clearly, grade honestly, report legibly, then prioritize, and the final prioritization will wait for the session 5 risk assessment, which will give each deviation its real weight in the group's security baseline. The audit measures; it does not decide in the place of those who decide. That is its limit, and that is its strength: because it decides nothing, nobody can dispute what it has measured.

+10 XP

Leçon terminée